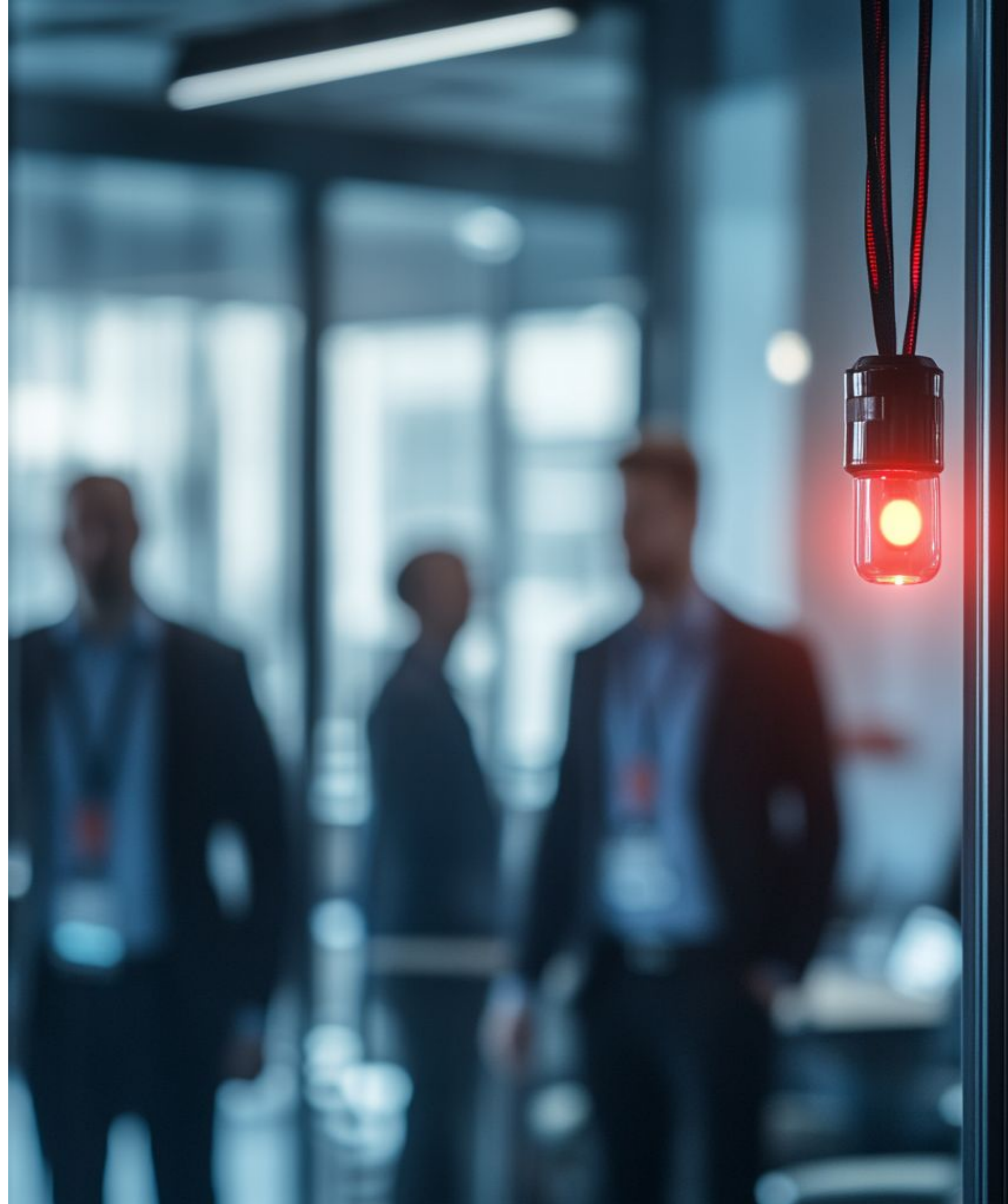


5. COMMON WEAK POINTS

Where you are most likely to fail
PCI DSS compliance, and why.



IMPLEMENTATION

IMPLEMENTATION COMMON WEAK POINTS

Naturally, as with other types of initiatives, there are commonly neglected points, where many organizations fall below the standard. In the PCI DSS, we usually have:

- Inadequate segmentation of networks;
- Inadequate access control implementation;
- Inconsistent vulnerability management/patching;
- Inadequate monitoring or logging;
- Inadequate data encryption practices;
- Inadequate security awareness training;
- Inadequate incident response planning;

Let's take a quick look at each of these.

IMPLEMENTATION

COMMON WEAK POINTS

First, inadequate segmentation of networks is a significant problem. Usually, one of two things occurs:

- Networks aren't properly segmented (so, either we have public traffic coming into the CDE, or we have all public networks considered the CDE, too, and must protect it);
- Networks are properly segmented, but aren't protected (we don't have IDS/IPS protection on the "border", or we don't apply strict configurations on CDE NSCs, for example);

Good practices here include:

- Having very accurate network diagrams (help segment);
- Paying special attention to points of interaction between CDE and public networks;
- Having strict, standardized configuration controls;





IMPLEMENTATION

IMPLEMENTATION COMMON WEAK POINTS

Then, inadequate access control is another issue. Common examples include:

- We have an AC mechanism, but not all roles are there;
- The AC mechanism has all roles, but privileges are not restricted or are not explicitly associated with roles;
- The AC mechanism is not updated;
- Other miscellaneous issues (weak passwords, lack of MFA for sensitive actions, exceptions) that compromise AC;

Good practices here include:

- Covering all roles, updated, with explicit privileges. Period;
- No exceptions. Someone needs a change, it goes through a formal change process with authorization;
- Restricting data and privileges as much as possible;

IMPLEMENTATION

COMMON WEAK POINTS

Then, inadequate vulnerability management or patching.

- Basically, this comes from bad inventorying practices in terms of software. If you don't know what you have, how can you protect it?
- The problem may also be the patching. Is it done ad-hoc? What is the timing? Is there a formal process? For all machines at the same time? Is it mandatory?

Good practices here include:

- Enforcing the critical patch 1-month timeframe, and the selected timeframe for others, strictly and mandatorily;
- Have processes for obtaining vulnerability information from multiple sources;
- Making devs code security protections, and auditing them;





IMPLEMENTATION

IMPLEMENTATION COMMON WEAK POINTS

Inadequate monitoring or logging is another issue:

- The most common problem is not logging all of the necessary details, or monitoring all systems. Just running the logger/monitor with the default settings;
- Not maintaining the loggers/monitors is another issue. If the application crashes, if it runs out of disk space, if a system's codes have changed and certain log records are now empty... certain organizations would not even notice;

Good practices here include:

- Being strict about everything that is logged, and regularly reviewing log contents to ensure this. Same for monitors;
- Ensuring that logging is activated for all systems, and that the log contents still make sense as they are updated;

IMPLEMENTATION

COMMON WEAK POINTS

Inadequate data encryption is another possible issue:

- The organization may not use proper encryption (at rest or in transit). Maybe the encryption is outdated and no one bothered to re-encrypt with a stronger protocol, maybe keys are not managed properly, etc;
- It can also be exceptions are made. If you encrypt all CHD data in traffic... except for one person, you're still done;

Good practices here include:

- Having strong protocols (e.g., AES-256), and ensuring keys are stored securely, separate from the encrypted data;
- Ensuring that all card data is encrypted, in all cases without exception, at rest and in transit;





IMPLEMENTATION

IMPLEMENTATION COMMON WEAK POINTS

Then, inadequate security awareness and training:

- This one's a bit different. It won't have immediate negative effects - but instead cause small, delayed, distributed problems everywhere. It's death by 1000 cuts;
- When people are not properly trained, they will start to crack in small and varied ways, in many different areas;
- A plaintext message, an unrecognized USB drive plugged in, a single laptop without anti-malware... and there we go;

Good practices here include:

- Having regular - and thorough - training for all personnel;
- Ensuring that each role receives proper training. Are they trained to do everything the current personnel does, or do they need to "learn on the job"? If so, it's not enough as is;

IMPLEMENTATION

COMMON WEAK POINTS

Finally, inadequate incident response planning also matters:

- This is one of those things that you won't realize 99% of the time, and then in the other 1% explodes. Incidents or breaches are usually urgent. If procedures for business continuity, data backups, account containment or others are not clear, believe me you *will* know very quickly;
- The only acceptable way here is to have a tested IR plan;

Good practices here include:

- Having a detailed IR plan in the first place, with all measures in terms of immediate actions, communication, continuity procedures, and more;
- Each key person should know their exact role and actions;



IMPLEMENTATION

COMMON WEAK POINTS

EXAMPLES

/01 EXCEPTIONS

Exceptions are one of the most dangerous actions (not just for PCI DSS, but all cybersecurity). It doesn't matter how strong a process is... if you don't follow it.

/02 INCONSISTENCY

A lot of issues come down to inconsistency. Encryption is used... but not always. Logs are reviewed... but not always. The "cure" is always strict, repeated processes.

/03 PROTECTING FROM PEOPLE

A lot of compliance professionals focus on only the controls, but, ironically, people are many times the weak point. The processes should protect from people.

IMPLEMENTATION

COMMON WEAK POINTS

KEY TAKEAWAYS

/01 POSSIBLE WEAK POINTS

There are many things that can become weak points or that can fail. It's crucial to double-check these areas, in specific, to ensure that your compliance is robust.

/03 ACCESS CONTROL

You need to ensure that your AC mechanism defines exact privileges by role, that there are no exceptions, and that people do see the least possible.

/02 NETWORK SEGMENTATION

If your CDE networks are segmented from the rest, you need to ensure that both the segmentation is done well and that the borders are protected.

/04 VULNERABILITY MGMT.

You need to track vulnerabilities well. Do we know which we have? Do we know which SW we have? What's the patching timeline? Is development secure?

IMPLEMENTATION

COMMON WEAK POINTS

KEY TAKEAWAYS

/05 MONITORING/LOGGING

Your monitoring systems and your loggers must cover all essential areas, without running into trouble, and you need to ensure their working and review logs.

/07 SEC. AWARENESS/TRAINING

Employees must receive proper - and regular - training, or the cracks will start to show. They must be trained to fulfill all requirements of their specific role.

/06 DATA ENCRYPTION

Data must always be encrypted with strong encryption. You can't have expired or weak keys, you can't have exceptions, and you must be consistent.

/08 INCIDENT RESPONSE

Finally, your IR plan must be robust. Everyone must know exactly what they need to do, and this must be documented - and, more importantly, tested.